Карта требований

Проект: BAS-платформа для автоматизированной проверки защищенности корпоративной ИТ-инфраструктуры
Фаза №1: Разработка и внутренняя апробация первой эксплуатационной версии

Версия: 0.1

Статус: рабочая карта требований для дальнейшего сбора и детализации

Цели и ценность продукта

Цель проекта

Разработать первую эксплуатационную версию BAS-платформы и провести ее внутреннюю апробацию на изолированных тестовых стендах и заранее согласованных контролируемых сегментах корпоративной ИТ-инфраструктуры

Ценность для внутренних пользователей

Платформа должна позволять:

- Проводить контролируемую симуляцию сценариев кибератак
- Проверять способность существующих сердств защиты обнаруживать и блкировать моделируемую активность
- Получать централизованные результаты проведения симуляций
- Повторно запускать утвержденные сценарии
- Безопасно завершать и откатывать результаты симуляций
- Выявлять ограничения текущих защитных мер

Результат Фазы №1

Результатом является не коммерческий продукт, а первая эксплуатационная версия, внутренняя апробация, подтвержденияе технологической реализуемости и формирование основы для решения о переходе к следующим фазам

Пользователи и заинтересованные лица

Оператор симуляций

Основные задачи:

- Выбирать сценарий
- Задавать параметры кампании
- Определять разрешенные цели
- Запускать и останавливать симуляцию
- Контролировать ход выполнения
- Анализировать результат
- Просматривать события и результаты обнаружения/блокировки
- Получать отчет

Аналитик ИБ

Основные задачи:

- Просматривать результаты кампаний
- Анализировать события
- Сопоставлять результаты с данными СЗИ
- Оценивать эффективность защитных механизмов
- Формировать выводы по результатам апробации

Администратор платформы

Основные задачи:

- Управлять пользователями и ролями
- Регистрировать и контролировать агентов
- Управлять конфигурацией
- Управлять версиями сценариев
- Контролировать состояние платформы
- ВЫполнять административные операции

Эксперт по сценариям

Основные задачи:

- Разрабатывать и валидировать сценарии
- Определять соответствие сценариев MITRE ATT&CK
- Задавать ожидаемые результаты
- Участвовать в оценке результатов симуляции
- Соглсовывать безопасные условия проведения атак

Директор ИБ (Заказчик)

Основные задачи:

- Формировать и согласовывать требования
- Утверждать сценарии и регламенты
- Принимать результаты апробации
- Оценивать полезность платформы

Управление пользователями и доступом

Ролевая модель

Платформа должна поддерживать как минимум роли:

- Администратор платформы
- Оператор симуляций
- Аналитик ИБ
- Эксперт по сценариям
- Руководитель ИБ

Аутентификация

- Обязательная аутентификация пользователей
- Двухфакторная аутентификация
- Разграничение прав доступа в соответствии с ролью

Уточнить на сборе требований:

- Интеграция с корпоративным IdP
- Требования к сроку жизни сессии
- Блокировка учетной записи
- Требования к паролям
- Требования к сервисным учетным записям

Авторизация

Пользователь должен иметь возможность выполнять только те операции, которые разрешены его ролью

Уточнить на сборе требований:

- Какие именно действия доступны каждой роли
- Может ли оператор самостоятельно создавать/изменять сценарии
- Кто имеет право запускать симуляцию в контролируемом сегменте
- Кто имеет право изменять настройки безопасности

Управление агентами и инфраструктурными компонентами

Регистрация агента

Платформа должна поддерживать:

- Регистрацию агента
- Аутентификациюю агента
- Индетификацию агента
- Отображение статуса агента
- Контроль доступности агента

Жизненный цикл агента

Необходимо поддержать:

- Регистрацию
- Аутентификацию
- Обновление версии
- Отключение
- Безопасное удаление
- Контроль состояния

Ограничение прав агента

Агент должен обладать минимально необходимыми правами в ОС

Контроль ресурсов

Для агента необходимо установить и проверить допустимые значения:

- CPU
- RAM

Целевое значение CPU из устава: не более 5% в пике при штатном выполнении сценария

Уточнить на сборе требований:

- Конкретный лимит RAM
- Допустимую длительность пикового потребления
- Проведение агента при превышении лимита

Управление сценариями атак

Репозиторий сценариев

Платформа должна предоставлять централизированное хранение сценариев

Для сценария должны храниться как миниммум:

- Идентификатор
- Описание

- Класс атаки
- MITRE ATT&CK маппинг
- Версия
- Ожидаемый результат
- Параметры запуска
- Требования к целевой среде
- Правила безопасного завершения

Классы сценариев Фазы №1

Минимальная граница:

1. Фишинг - не менее 2 сценариев
2. Сетевые атак - не менее 2 сценариев
3. Имитация распространения вредоносного ПО - не менее 2 сценариев

Итого - не менее 6 утвержденных сценариев

Версионирование

Необходимо обеспечить контролируемое обновление сценариев:

- Хранение версии
- Изменение версии
- Предварительное тестирование
- Возможность отката версии

Безопасность сценария

Перед запуской сценарий должен проходить необходимые проверки и ограничения

Уточнить на сборе требований:

- Кто утверждает сценарий
- Какие статусы имеет сценарий
- Какие проверки обязательны перед переводом в доступные для запуска
- Может ли сценарий запускаться повторно
- Кто имеет право изменять утвержденный сценарий

Управление кампаниями и заупском симуляций

Создание кампании

Пользователь должен иметь возможность:

- Выбрать сценарий
- Выбрать целевые системы/фгенты
- Задать параметры запуска
- Определить время запуска
- Сформировать кампанию

Запуск

Поддерживаются:

- Запуск по расписанию
- Запуск в реальном времени/вручную

Предварительные проверки

До запуска должны проверять как минимум:

- Допустимость цели
- Наличие цели в белом списке
- Отсуствие цели в черном списке
- Лимит параллельных запусков
- Лимит времени выполнения
- Разрешение оператора
- Допустимость конкретного сценария

Управление выполнением

Необходимо обеспечить:

- Отображение статуса кампании
- Остановку выполнения
- Безопасное завершение
- Переход в безопасное состояние при потере связи с критическим компонентом

Kill Switch

Платформа должна иметь механизм экстренной остановки симуляции

Для версии Фазы №1 принимается следующая модель:

- Оператор может экстренно остановить активную кампанию
- Администратор платформы имеет право выполнить глобальную аварийную остановку всех активных кампаний
- После активации kill switch новые действия сценария не запускаются
- Агенты прекращают выполнение активных действий и переходят в безопасное состояние
- Начало остановки должно быть инициировано не позднее 30 секунд с момента подтверждения команды kill switch
- Возобновление симуляций после глобальной аварийной остановки возможно только после завершения проверки инцидента и разрешения уполномоченного сотрудника ИБ

Безопасность и выполнение отката

Предварительное тестирование

Каждый сценарий должен быть протестирован на изолированном stage-стенде до допуска к контролируемой внутренней апробации

Откат и очистка

Для 100% сценариев первой эксплуатационной версии должен существовать и быть протестирован механизм отката

Он должн обеспечивать удаление созданных в ходе симуляции артефактов, включая предусмотренные сценарием:

- Файлы
- Службы
- Ветви реестра
- Учетные записи
- Другие создаваемые артефакты

Контроль целевой среды

Необходимо поддержать:

- Белый список целей
- Чернвй список критических сегментов
- Ограничение параллельных запусков

- Ограничения времени выполнения
- Запрет потенциально разрушительных действий

Поведение при инциденте

При возникновении инцидента, связанного с платформой или симуляцией:

- Новые симуляции блокируются
- Выполняющиеся процессы переводятся в безопасное состояние
- Дальнейшие запуски разрешаются только после асследования и соответствующего разрешения

Мониторинг и наблюдаемость

Мониторинг состояния платформы

Необходимо отображать:

- Доступность Сервера управления
- Доступность агентов
- Состояние кампаний
- Состояние сценариев
- Ошибки выполнения
- Критические системные события

Логирование

Все действия платформы должны фиксироваться в журнале аудита

Необходимо обеспечить:

- Фиксацию действий пользователей
- Фиксацию действий агентов
- Фиксацию запусков сценариев
- Фиксацию административных операций
- Фкисацию ошибок
- Защиту журанала от некорректируемого изменения

Уточнить на сборе требований:

- Срок хранения
- Объем журналов
- Поиск и фильтрацию
- Экспорт
- Требования к временной синхронизации

Интеграция с СЗИ

SIEM

В Фазе №1:

- Интеграция минимум с одной корпоративной SIEM
- Получение необходимых логов
- Сопоставление событий с запущенной атакой
- Фиксация результата обнаружения

EDR

В Фазе №1:

- Интеграция минимум с одним корпоративным EDR
- Получение необходимой телеметрии
- Фиксация результата обнаружения
- Фиксация результата предотвращения

Результат проверки

Для каждого сценария необходимо фиксировать:

- обнаружен / не обнаружен
- заблокирован / не заблокирован
- результат не определен из-за отсутствия или неполноты телеметрии

Ограничение интеграций

Уточнить на сборе требований:

- Конкретный SIEM и EDR
- Доступные API
- Формат данных
- Ограничения API
- Переодичность получения данных
- Допустимую задержку получения телеметрии
- Правила обработки отсутствующей телеметрии

Дашборд и отчетность

Дашборд

Дашборд должен позволять видеть:

- Активные кампании
- Статусы кампаний
- Результаты сценариев
- Результаты обнаружения
- Результаты блокироваки
- Ошибки
- Состояние агентов
- Состояние платформы

Аналитика

Необходимо предусмотреть визуализацию:

- Результатов тестирования
- Покрытия сценариями
- Результатов работы СЗИ
- Связанных событий

Отчеты

Платформа должна поддерживать генерацию отчетов по результатам симуляции

Уточнить на сборе требований:

- Формат отчетов

- Обязательные разделы
- Отчет по одной кампании или сводный
- Возможность экспорта
- Требования к правам доступа к отчетам

Хранение данных и артефактов

Хранение

Необходимо определить хранение:

- Сценариев
- Конфигурации
- Результатов кампаний
- Логов
- Аудита
- Артефактов симуляций
- Отчетов

Защита

Хранилища сценариев и вредоносных артефактов должны быть:

- Зашифрованы
- Доступны только авторизованным польхователям/сервисам
- Защищены разграничением прав

Уточнить на сборе требований:

- Сроки хранения
- Резервное копирование
- Восстановление
- Требование к отказоустойчивости
- Объем данных

Нефункциональные требование

Безопасность

- Защищенный как от Сервера через Прокси к Агенту
- Взаимная аутентификация
- MFA для пользователей
- Минимальные права агентов
- Аудит действий
- Шифрование репозиториев
- DevSecOps проверки
- Контроль сторонних компонентов

Производительность

Зафиксированное требование:

- CPU агента ≤ 5% в пике при штатном выполнении сценария

Дополнительно уточнить:

- RAM
- Допустимую задержку запуска
- Количество одновременно выполняемых кампаний
- Количество агентов
- Количество сценариев
- Объем обрабатываемой телеметрии

Надежность

Необходимо определить:

- Поведение при недоступности Сервера управления
- Поведение при потере агента
- Восстановление после сбоя
- Требования к доступности компонентов

Зафиксировано в уставе: при недоступности Сервера управления или потере связи с агентом новые сценарии не должны запускаться, а активная кампания должна перейти в безопасное состояние

Совместимость

Агенты должны поддерживать осовные ОС корпоративной сети:

- Windows
- Linux

Масштабируемость

Архитектура Фазы №1 должна позволять дальнейшее расширение:

- Набора сценариев
- Интеграций
- Функциональности
- Мультиарендности в последующих фазах

DevSecOps и разработка

CI/CD

Необходимо обеспечить:

- Автоматизированную сборку
- Автоматические проверки
- Контроль зависимостей
- Сканирование кода
- Безопасное хранение артефактов

Тестирование

Минимальный набор:

- Unit-тестирование компонентов ядра
- Нагрузочное тестирование агентов
- Тестирование сценариев
- Тестирование отката
- Итеграционное тестирование с СЗИ
- Регрессионное тестирование

Stage

До допуска сценаря к внутренней апробации должны быть выполнены:

1. Разработка
2. Тестирование на stage
3. Проверка безопасности
4. Проверка отката
5. Утверждение сценари

Внутренняя апробация

Среда

Апробация проводится:

- На stage
- В заранее согласованных контролируемых сегментах корпоративной инфраструктуры

Сценарии

Должны быть проведены сценарии трех классов:

- Фишинг
- Сетевые атаки
- Имитация распространения ВПО

Всего не менее 6 утвержденных сценариев

Результаты апробации

Необходимо получить:

- Результаты выполнения сценариев
- Результаты обнаружения
- Результаты блокировки
- Выявленные недостатки защитных мер
- Выявленные ограничения платформы
- Технические замечания
- Результаты регрессионного тестирования

Критерии безопасности апробации

- 0 критических инцидентов, вызванных платформой
- 0 случаев недоступности критических продуктовых сервисов из-за выполнения сценариев
- Наличие отката для каждого сценария

Документация и передача в эксплуатацию

Техническая документация

Должна описывать минимум:

- Архитектуру
- Развертывание
- Конфигурацию
- Интеграции
- Управление агентами

- Управление сценариями
- Процедуры обновления
- Процедуры отката

Пользовательская документация

Должна описывать:

- Работу с интерфейсом
- Создание и запуск кампаний
- Просмотр результатов
- Работу с отчетами
- Действия при возникновении инцидента

Эксплуатационная готовность

До передачи:

- Настроены роли и доступы
- Подготовлена документация
- Проведен инструктаж сотрудников ИБ
- Опеделены ответственные за сопровождение
- Определены ответственные за обработку инцидентов
- Определены ответственные за обновление сценариев

Ограничения и рамки Фазы №1

В границах:

- Внутренняя эксплуатация
- Разработка первой эксплуатационной версии
- Минимум 6 сценариев
- Минимум 1 SIEM
- Минимум 1 EDR
- Windows/Linux
- stage + согласованные контролируемые сегменты
- Внутренняя документация

Не входит:

- Внешние B2B-пилоты
- Адаптация под инфраструтктуру внешних клиентов
- Мультиарендность
- Биллинг
- Прием платежей
- Коммерческие продажи
- Маркетинговая упаковка

Открытые вопросы для следующей волны сбора требований

Пользователи

1. ~~Кто конкретно является оператором платформы?~~
2. ~~Какие действия доступны каждой роли?~~

3. ~~Кто имеет право финального запуска симуляции?~~
4. ~~Кто утверждает сценарий?~~

Решение для версии 0.1: оператором платформы является специалист, ответственный за запуск и контроль утвержденных кампаний. Распределение действий между ролями определяется ролевой моделью USM. Финальный запуск выполняет оператор после прохождения автоматических проверок и явного подтверждения. Сценарий разрабатывает и валидирует эксперт по сценариям, окончательное утверждение сценария выполняет Директор по ИБ как внутренний Заказчик

Сценарии

5. Какие именно 6 сценариев входят в первую эксплуатационную версию?
6. Какие техники MITRE ATT&CK должны быть покрыты?
7. Какие сценарии считаются безопасными для контролируемого сегмента?
8. Какие действия категорически запрещены?

Целевые системы

9. Какие типы конечных устройств?
10. Какие сегменты инфраструктуры допустимы для апробации?
11. Какие сегменты всегда запрещены?

SIEM/EDR

12. ~~Какие конкретно SIEM и EDR выбирает Заказчик?~~

    > MaxPatrol SIEM + MaxPatrol EDR

13. Какие API доступны?
14. ~~Какие данные необходимы для определения "обнаружен"?~~

    > Обнаружение считается подтвержденным при наличии в SIEM события/алерта, сопоставленного с идентификатором кампании и временным интервалом выполнения соответствующего действия сценария

15. ~~Какие данные необходимы для определения "заблокирован"?~~

    > Блокировка считается подтвержденной при наличии в EDR телеметрии или события, однозначно указывающего на предотвращение соответствующего действия

16. ~~Какие данные приводят к определению "не определен"?~~

    > При отсутствии достаточной телеметрии результат фиксируется как «не определен», без интерпретации отсутствия события как успешной блокировки

Производительность и масштаб

17. ~~Сколько агентов должно поддерживаться?~~

    > До 100 агентов

18. ~~Сколько одновременный кампаний?~~

    > До 5 параллельных кампаний

19. ~~Какой объем логов?~~

    > Предварительный объем телеметрии определяется в рамках архитектурного размера на основании принятого количества агентов и ожидаемой интенсивности событий

20. ~~Какой лимит RAM агента?~~

    > RAM ≤100 МБ

21. ~~Как быстро должна останавливаться активная симуляция?~~

    > kill switch 30 секунд

Безопасность

22. Как именно реализуется kill switch?
23. ~~Как организуется взаимная аутентификация?~~

> Взаимная аутентификация между Сервером управления, Прокси-нодами и Агентами реализуется с использованием взаимного TLS (mTLS) на основе корпоративной PKI. Сертификаты компонентов должны иметь ограниченный срок действия и контролируемый процесс выпуска и отзыва

24. ~~Какой корпоративный механизм MFA используется?~~

> Для версии 0.1 принимается Keycloak как корпоративный Identity Provider, интегрированный с LDAP/Active Directory. Второй фактор — TOTP. Конкретная интеграция с корпоративным каталогом уточняется на архитектурном проектировании

25. ~~Как долго хранятся аудит и результаты?~~

> 180/365 дней

26. ~~Какие требования к резервному копированию?~~

> ежедневный backup, RPO/RTO

Апробоция

27. ~~Какие критерии определяют успешность каждого сценария?~~

> Сценарий считается успешно выполненным, если:
>
> a. Выполнены все предусмотренные сценарием действия
> b. Действия выполнялись только в разрешенной целевой среде
> c. Ожидаемый результат выполнения зафиксирован
> d. Результат обнаружения/блокировки СЗИ зафиксирован либо отмечен как «не определен» при недостаточности телеметрии
> e. Выполнены предусмотренные сценарием очистка и/или откат
> f. Отсутствуют критические нарушения правил безопасного выполнения

28. ~~Кто подписывает результат апробации?~~

> Внутренний Заказчик принимает результаты апробации, Спонсор принимает решение о завершении Фазы №1

29. ~~Как фиксируется обнаружение/блокировка СЗИ?~~

> Обнаружение/блокировка фиксируются на основании событий SIEM/EDR, сопоставленных с ID кампании и временным интервалом выполнения соответствующего действия сценария. При недостаточности телеметрии результат фиксируется как "не определен"

30. ~~Какие условия необходимы для допуска платформы к следующей фазе?~~

> Критерии перехода к Фазе №2 зафиксированы в Уставе проекта и включают технологическую готовность, операционную ценность, повторяемость сценариев и архитектурную готовность к дальнейшему масштабированию

Принятые проектные допущения для версии 0.1

В связи с отсутствием на текущем этапе реального Заказчика часть параметров, необходимых для подготовки первой версии концептуального ТЗ, принимается как проектные допущения. Данные параметры используются для формирования точки отсчета Фазы №1 и подлежат последующей валидации на этапе детального проектирования и архитектурного планирования

Область	Принятое допущение для Фазы №1	Статус
SIEM	MaxPatrol SIEM	Проектное допущение
EDR	MaxPatrol EDR	Проектное допущение
Аутентификация	Корпоративный IdP на базе Keycloak с интеграцией с LDAP/Active Directory	Проектное допущение
MFA	TOTP как второй фактор аутентификации	Проектное допущение
ОС агентов	Windows и Linux	Зафиксировано
Количество агентов	До 100 одновременно зарегистрированных агентов	Проектное допущение
Параллельные кампании	До 5 одновременно выполняемых кампаний	Проектное допущение

RAM агента	Не более 100 МБ в пиковом потреблении при штатном выполнении сценария	Предварительное целевое значение
Время реакции интерфейса	Не более 3 секунд для 95% стандартных операций интерфейса	Предварительное целевое значение
Задержка получения телеметрии	Целевое значение не более 60 секунд для поступления и первичной корреляции события	Предварительное целевое значение
Экстренная остановка	Начало остановки всех действий активной кампании не более 30 секунд с момента подтверждения kill switch	Предварительное целевое значение
Хранение результатов симуляций	180 дней	Предварительное значение
Хранение журнала аудита	365 дней	Предварительное значение
Резервное копирование	Ежедневное резервное копирование критичных данных	Проектное допущение
RPO	Не более 24 часов	Предварительное целевое значение
RTO	Не более 4 часов	Предварительное целевое значение

Указанные параметры не рассматриваются как окончательные отраслевые нормативы. Они используются для формирования первой версии концептуального ТЗ и должны быть подтверждены в ходе детального проектирования и технических исследований.

оператор может экстренно остановить активную кампанию;

• администратор платформы имеет право выполнить глобальную аварийную остановку всех активных кампаний;

• после активации kill switch новые действия сценария не запускаются;

• агенты прекращают выполнение активных действий и переходят в безопасное состояние;

• начало остановки должно быть инициировано не позднее 30 секунд с момента подтверждения команды kill switch;

• возобновление симуляций после глобальной аварийной остановки возможно только после завершения проверки инцидента и разрешения уполномоченного сотрудника ИБ.